LMS Architecture & Workflow

Mari Energies Ltd — Land Management System · system layers, roles, modules, end-to-end approval workflow and controls

Deliverable 04 · 31 Oct 2026
Reflects the code and database **lms_dev at migration 0059**
Provinces: Sindh (SND) · Balochistan (BAL) · Punjab (PNJ) · Khyber Pakhtunkhwa (KPK)

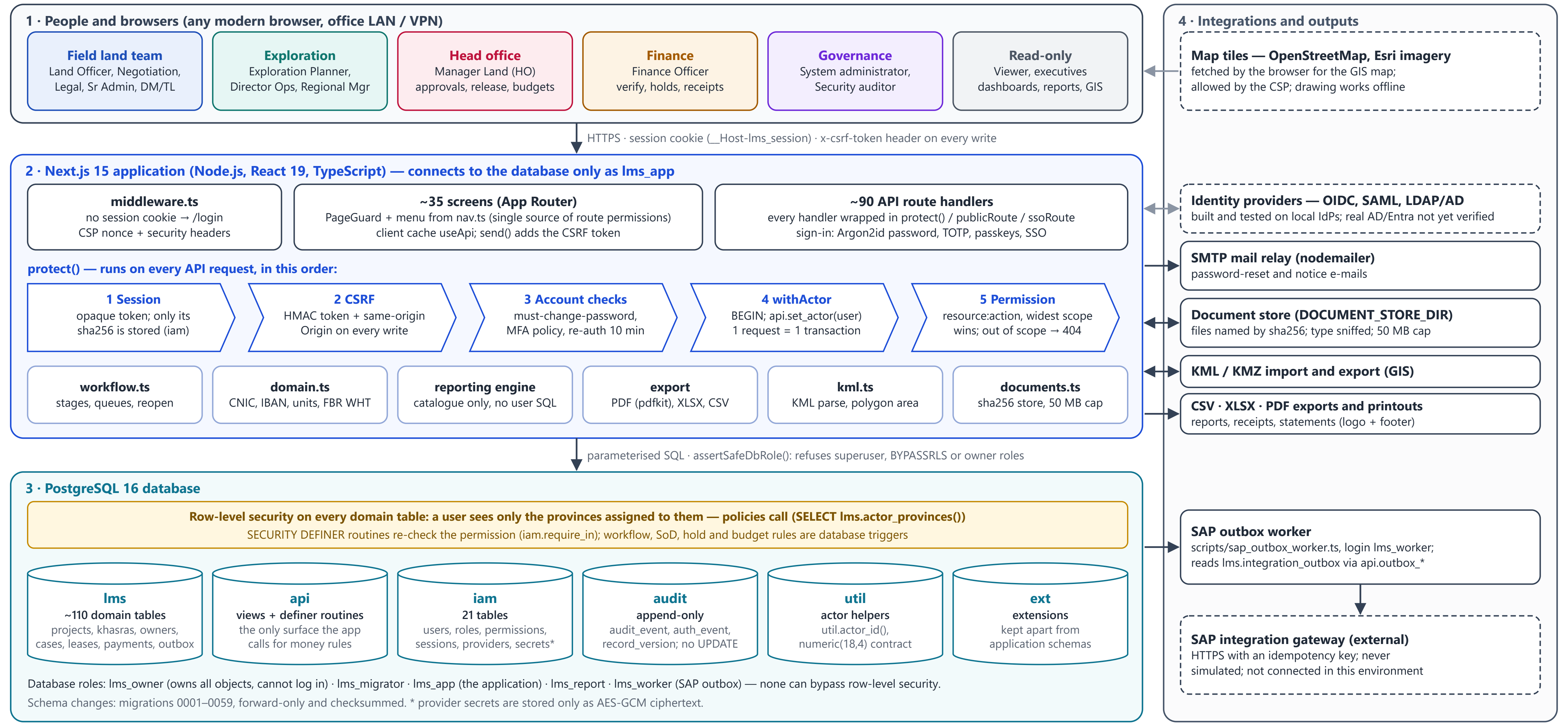
ROLE GROUPS ☐ Governance & audit ☐ Exploration & land-request review ☐ Field land team ☐ Head office (Manager Land) ☐ Finance ☐ Read-only ☐ System (automatic)

MODULE GROUPS ☐ Overview ☐ Master Data ☐ Land Operations ☐ Finance ☐ Community ☐ Records & Reports ☐ System

LINES → flow / data dependency - - → return for changes, or payment hold → external service ⬚ dashed box = external, or not yet verified in production

A System architecture

Four layers. The browser talks only to the Next.js application. Every API call passes the five protect() checks and runs as one database transaction tagged with the signed-in user, so PostgreSQL itself enforces province scope, approval rules and the audit trail. External services sit on the right.



1 · People and browsers (any modern browser, office LAN / VPN)

Field land team
Land Officer, Negotiation, Legal, Sr Admin, DM/TL

Exploration
Exploration Planner, Director Ops, Regional Mgr

Head office
Manager Land (HO)
approvals, release, budgets

Finance
Finance Officer
verify, holds, receipts

Governance
System administrator, Security auditor

Read-only
Viewer, executives
dashboards, reports, GIS

HTTPS · session cookie (__Host-lms_session) · x-csrf-token header on every write

2 · Next.js 15 application (Node.js, React 19, TypeScript) — connects to the database only as lms_app

middleware.ts
no session cookie → /login
CSP nonce + security headers

~35 screens (App Router)
PageGuard + menu from nav.ts (single source of route permissions)
client cache useApi; send() adds the CSRF token

~90 API route handlers
every handler wrapped in protect() / publicRoute / ssoRoute
sign-in: Argon2id password, TOTP, passkeys, SSO

protect() — runs on every API request, in this order:

1 Session
opaque token; only its sha256 is stored (iam)

2 CSRF
HMAC token + same-origin Origin on every write

3 Account checks
must-change-password, MFA policy, re-auth 10 min

4 withActor
BEGIN; api.set_actor(user)
1 request = 1 transaction

5 Permission
resource:action, widest scope wins; out of scope → 404

workflow.ts
stages, queues, reopen

domain.ts
CNIC, IBAN, units, FBR WHT

reporting engine
catalogue only, no user SQL

export
PDF (pdfkit), XLSX, CSV

kml.ts
KML parse, polygon area

documents.ts
sha256 store, 50 MB cap

parameterised SQL · assertSafeDbRole(): refuses superuser, BYPASSRLS or owner roles

3 · PostgreSQL 16 database

Row-level security on every domain table: a user sees only the provinces assigned to them — policies call (SELECT lms.actor_provinces())
SECURITY DEFINER routines re-check the permission (iam.require_in); workflow, SoD, hold and budget rules are database triggers

lms
~110 domain tables
projects, khasras, owners, cases, leases, payments, outbox

api
views + definer routines
the only surface the app calls for money rules

iam
21 tables
users, roles, permissions, sessions, providers, secrets*

audit
append-only
audit_event, auth_event, record_version; no UPDATE

util
actor helpers
util.actor_id(), numeric(18,4) contract

ext
extensions
kept apart from application schemas

Database roles: lms_owner (owns all objects, cannot log in) · lms_migrator · lms_app (the application) · lms_report · lms_worker (SAP outbox) — none can bypass row-level security.

Schema changes: migrations 0001–0059, forward-only and checksummed. * provider secrets are stored only as AES-GCM ciphertext.

4 · Integrations and outputs

Map tiles — OpenStreetMap, Esri imagery
fetched by the browser for the GIS map;
allowed by the CSP; drawing works offline

Identity providers — OIDC, SAML, LDAP/AD
built and tested on local IdPs; real AD/Entra not yet verified

SMTP mail relay (nodemailer)
password-reset and notice e-mails

Document store (DOCUMENT_STORE_DIR)
files named by sha256; type sniffed; 50 MB cap

KML / KMZ import and export (GIS)

CSV · XLSX · PDF exports and printouts
reports, receipts, statements (logo + footer)

SAP outbox worker
scripts/sap_outbox_worker.ts, login lms_worker;
reads lms.integration_outbox via api.outbox_*

SAP integration gateway (external)
HTTPS with an idempotency key; never
simulated; not connected in this environment